

BONUS 2

Isolare un Host Compromesso usando la 5-Tupla

Team Amaterasu

Obiettivi

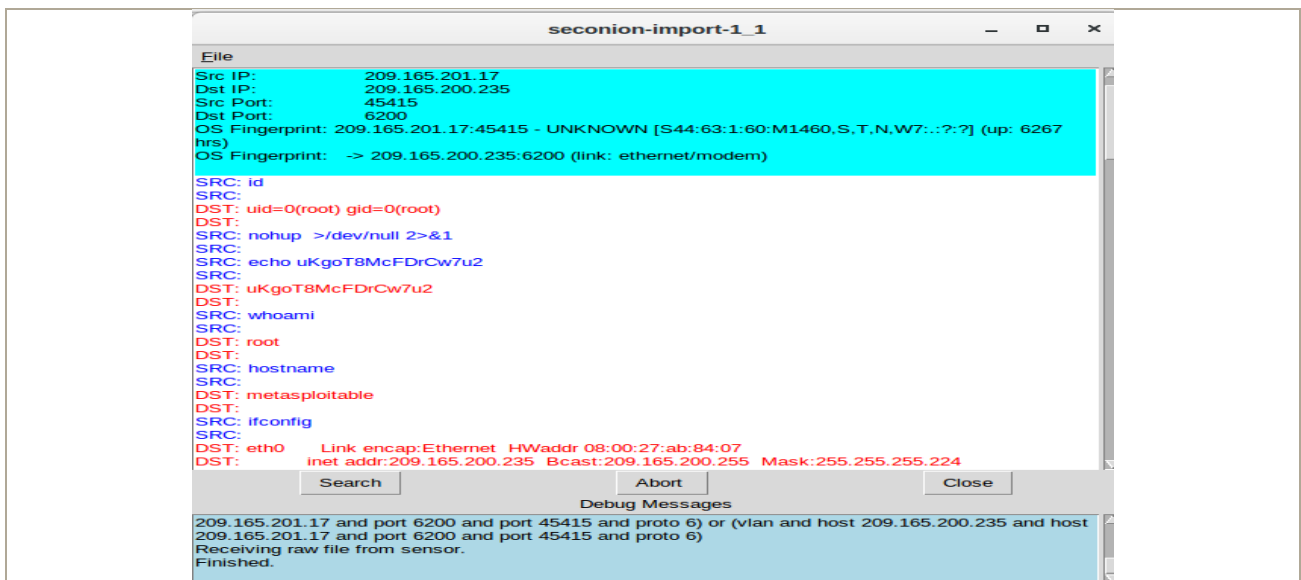
In questo laboratorio, esaminerai i log raccolti durante lo sfruttamento di una vulnerabilità documentata per determinare gli host e il file compromessi.

- Parte 1: Esaminare gli Alert in Sguil
- Parte 2: Passare a Wireshark (Pivoting)
- Parte 3: Passare a Kibana (Pivoting)

Parte 1: Esaminare gli Alert in Sguil

L'attività svolta parte dall'accesso alla macchina virtuale Security Onion con l'utente analyst e dal successivo avvio dell'applicazione Sguil su tutte le interfacce. Si è proceduto all'ispezione degli eventi individuando l'allarme critico GPL ATTACK_RESPONSE id check returned root (relativo al traffico tra l'attaccante 209.165.201.17 e la vittima 209.165.200.235), abilitando le opzioni Show Packet Data e Show Rule per esaminare la regola e il payload. Infine, tramite la funzione Transcript sull'ID dell'alert, è stata analizzata la trascrizione completa del flusso per ricostruire la sequenza dei comandi Linux inviati ed eseguiti da remoto sulla macchina bersaglio.

D Che tipo di transazioni si sono verificate tra client e server in questo attacco?



R

Tra il client dell'attaccante (209.165.201.17) e il server bersaglio (209.165.200.235) si sono verificate transazioni di esecuzione remota di comandi di shell. L'attaccante ha inviato comandi di sistema Linux al server bersaglio per verificare e sfruttare l'accesso con privilegi di root (come confermato dall'output del comando id check restituito dal server), procedendo poi all'esplorazione interattiva del file system della macchina compromessa per accedere e modificare file di sistema sensibili come /etc/passwd e /etc/shadow.

Parte 2: Passare a Wireshark (Pivoting)

Selezionando l'alert 5.1 all'interno dell'interfaccia di Sguil e facendo clic con il pulsante destro del mouse sul relativo ID, si è aperta la sessione di cattura direttamente in Wireshark. Da qui, selezionando un qualsiasi pacchetto appartenente alla conversazione e avviando la funzione Follow > TCP Stream, si è ricostruito l'intero flusso della comunicazione TCP in formato testo.

D Cosa hai osservato? Cosa indicano i colori del testo rosso e blu?



R

Nella finestra Follow TCP Stream si osserva la sessione di comunicazione completa e in chiaro tra l'attaccante e la macchina bersaglio, che mostra la sequenza dei comandi di shell inviati e il relativo output restituito dal sistema. I colori del testo identificano la direzione del traffico all'interno della connessione TCP: il testo in rosso rappresenta i dati inviati dal client (l'attaccante che invia le richieste e i comandi), mentre il testo in blu rappresenta i dati inviati dal server (la macchina bersaglio che restituisce la risposta e l'output dell'esecuzione dei comandi).

D L'attaccante esegue il comando whoami sul bersaglio. Cosa rivela questo sul ruolo dell'attaccante sul computer bersaglio?

R

L'esecuzione del comando whoami serve a verificare l'identità e il livello di autorizzazione dell'account utente con cui si stanno eseguendo i comandi sulla macchina bersaglio. Il fatto che restituisca root rivela che l'attaccante ha ottenuto i massimi privilegi di sistema sull'host compromesso, confermandogli il controllo totale sulla macchina e la capacità di accedere a qualsiasi file riservato, modificare configurazioni o eseguire comandi senza alcuna restrizione.

D Scorri il flusso TCP. Che tipo di dati ha letto l'attore della minaccia?

R

1. Informazioni sull'Host e Rete (id, whoami, hostname, ifconfig)

- Identità e Privilegi: Conferma che l'utente corrente è root (UID 0, GID 0).
- Hostname: Nome del sistema compromesso (metasploitable).
- Configurazione di Rete: Indirizzo IP dell'interfaccia eth0 (209.165.200.235), maschera di sottorete (255.255.255.224), indirizzo broadcast (209.165.200.255), indirizzo MAC (08:00:27:ab:84:07) e interfaccia di loopback (127.0.0.1).

```

id
uid=0(root) gid=0(root)
nohup >/dev/null 2>&1
echo uKgoT8McFDrCw7u2
uKgoT8McFDrCw7u2
whoami
root
hostname
metasploitable
ifconfig
eth0      Link encap:Ethernet  HWaddr 08:00:27:ab:84:07
          inet addr:209.165.200.235  Bcast:209.165.200.255  Mask:255.255.255.224
          inet6 addr: fe80::a00:27ff:feab:8407/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:117 errors:0 dropped:0 overruns:0 frame:0
          TX packets:167 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:10294 (10.0 KB)  TX bytes:20187 (19.7 KB)
          Interrupt:17 Base address:0x2000

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128 Scope:Host
          UP LOOPBACK RUNNING  MTU:16436  Metric:1
          RX packets:512 errors:0 dropped:0 overruns:0 frame:0
          TX packets:512 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:225633 (220.3 KB)  TX bytes:225633 (220.3 KB)

```

2. Hash delle Password (cat /etc/shadow)

L'attaccante ha estratto gli hash crittografati in formato MD5-crypt (\$1\$) delle password di tutti gli utenti reali del sistema:

- root: \$1\$/avpfBJ1\$x0z8w5UF9Iv./DR9E9Lid.
- sys: \$1\$fUX6BP0t\$MiyC3UpOzQJqz4s5wFD910
- klog: \$1\$f2ZVMS4K\$R9Xkl.CmLdHhdUE3X9jqP0
- msfadmin: \$1\$XN10Zj2c\$Rt/zzCW3mLtUWA.ihZjA5/
- postgres: \$1\$Rw35ik.x\$MgQgZuU05pAoUvfJhfcYe/
- user: \$1\$HESu9xrh\$K.o3G93DGoXliQKkPmUgZ0
- service: \$1\$kR3ue7JZ\$7GxELDupr50hpcjZ3Bu//

```

cat /etc/shadow
root:$1$/avpfBJ1$x0z8w5UF9Iv./DR9E9Lid.:14747:0:99999:7:::
daemon:*:14684:0:99999:7:::
bin:*:14684:0:99999:7:::
sys:$1$fUX6BP0t$MiyC3UpOzQJqz4s5wFD910:14742:0:99999:7:::
sync:*:14684:0:99999:7:::
games:*:14684:0:99999:7:::
man:*:14684:0:99999:7:::
lp:*:14684:0:99999:7:::
mail:*:14684:0:99999:7:::
news:*:14684:0:99999:7:::
uucp:*:14684:0:99999:7:::
proxy:*:14684:0:99999:7:::
www-data:*:14684:0:99999:7:::
backup:*:14684:0:99999:7:::
list:*:14684:0:99999:7:::
irc:*:14684:0:99999:7:::
gnats:*:14684:0:99999:7:::
nobody:*:14684:0:99999:7:::
libuuid:*:14684:0:99999:7:::
dhcp:*:14684:0:99999:7:::
syslog:*:14684:0:99999:7:::
klog:$1$f2ZVMS4K$R9Xkl.CmLdHhdUE3X9jqP0:14742:0:99999:7:::
sshd:*:14684:0:99999:7:::
msfadmin:$1$XN10Zj2c$Rt/zzCW3mLtUWA.ihZjA5/:14684:0:99999:7:::
bind:*:14685:0:99999:7:::
postfix:*:14685:0:99999:7:::
ftp:*:14685:0:99999:7:::
postgres:$1$Rw35ik.x$MgQgZuU05pAoUvfJhfcYe/:14685:0:99999:7:::
mysql:*:14685:0:99999:7:::
tomcat55:*:14691:0:99999:7:::
distccd:*:14698:0:99999:7:::
user:$1$HESu9xrh$K.o3G93DGoXliQKkPmUgZ0:14699:0:99999:7:::
service:$1$kR3ue7JZ$7GxELDupr50hpcjZ3Bu//:14715:0:99999:7:::
telnetd:*:14715:0:99999:7:::
proftpd:*:14727:0:99999:7:::
statd:*:15474:0:99999:7:::

```

3. Mappatura degli Utenti di Sistema (cat /etc/passwd)

L'elenco degli account con le relative directory home e shell assegnate:

- Utenti con shell interattiva (/bin/bash): root, msfadmin, postgres, user, service, analyst.
- Account di servizio con shell disabilitata (/bin/false o /sbin/nologin): daemon, bin, sys, sshd, dhcp, mysql, tomcat55, ecc.

```
cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/bin/sh
bin:x:2:2:bin:/bin:/bin/sh
sys:x:3:3:sys:/dev:/bin/sh
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/bin/sh
man:x:6:12:man:/var/cache/man:/bin/sh
lp:x:7:7:lp:/var/spool/lpd:/bin/sh
mail:x:8:8:mail:/var/mail:/bin/sh
news:x:9:9:news:/var/spool/news:/bin/sh
uucp:x:10:10:uucp:/var/spool/uucp:/bin/sh
proxy:x:13:13:proxy:/bin:/bin/sh
www-data:x:33:33:www-data:/var/www:/bin/sh
backup:x:34:34:backup:/var/backups:/bin/sh
list:x:38:38:Mailing List Manager:/var/list:/bin/sh
irc:x:39:39:ircd:/var/run/ircd:/bin/sh
gnats:x:41:41:Gnats Bug-Reporting System (admin)/var/lib/gnats:/bin/sh
nobody:x:65534:65534:nobody:/nonexistent:/bin/sh
libuuid:x:100:101:/var/lib/libuuid:/bin/sh
dhcp:x:101:102:/nonexistent:/bin/false
syslog:x:102:103:/home/syslog:/bin/false
klog:x:103:104:/home/klog:/bin/false
sshd:x:104:65534:/var/run/sshd:/usr/sbin/nologin
msfadmin:x:1000:1000:msfadmin,,,:/home/msfadmin:/bin/bash
bind:x:105:113:/var/cache/bind:/bin/false
postfix:x:106:115:/var/spool/postfix:/bin/false
ftp:x:107:65534:/home/ftp:/bin/false
postgres:x:108:117:PostgreSQL administrator,,,:/var/lib/postgresql:/bin/bash
mysql:x:109:118:MySQL Server,,,:/var/lib/mysql:/bin/false
tomcat55:x:110:65534:/usr/share/tomcat5.5:/bin/false
distccd:x:111:65534:/bin/false
user:x:1001:1001:just a user,111,,:/home/user:/bin/bash
service:x:1002:1002,,,:/home/service:/bin/bash
telnetd:x:112:120:/nonexistent:/bin/false
proftpd:x:113:65534:/var/run/proftpd:/bin/false
statd:x:114:65534:/var/lib/nfs:/bin/false
analyst:x:1003:1003:Security Analyst,,,:/home/analyst:/bin/bash
```

4. Iniezione di una Backdoor (Operazione di Scrittura)

Oltre alla sola lettura, la parte finale dello stream mostra l'attaccante che sfrutta i privilegi di root per alterare i file di sistema e garantirsi la persistenza:

- Ha aggiunto la riga myroot::14747:0:99999:7:: nel file /etc/shadow.
- Ha aggiunto la riga myroot:x:0:0:root:/root:/bin/bash nel file /etc/passwd.
- Risultato: È stato creato un utente clone di root (myroot) con UID/GID 0 e senza password, che permette all'attaccante di rientrare nel sistema in qualsiasi momento senza bisogno di autenticarsi.

```
cat /etc/passwd | grep root
root:x:0:0:root:/root:/bin/bash
echo "myroot:x:0:0:root:/root:/bin/bash" >> /etc/passwd
grep root /etc/passwd
root:x:0:0:root:/root:/bin/bash
myroot:x:0:0:root:/root:/bin/bash
exit
```

Parte 3: Passare a Kibana

Per analizzare l'eventuale esfiltrazione del file confidential.txt tramite protocollo FTP, dall'interfaccia di Sguil si è effettuato il pivoting verso Kibana selezionando l'opzione Kibana IP Lookup > SrcIP tramite il pulsante destro sull'indirizzo IP dell>alert 5.1 e autenticandosi con le credenziali dell'analista. All'interno della dashboard di Kibana, l'ispezione del grafico Sensors - Sensors and Services ha rilevato la presenza di attività legate ai servizi ftp e ftp-data. Per isolare le sole sessioni di controllo, si è applicato un filtro specifico sulla voce bro_ftp. Questa operazione ha ridotto i dati presenti nella sezione All Logs a due sole voci dettagliate, permettendo di identificare con precisione i parametri di rete della connessione.

D Quali sono gli indirizzi IP e i numeri di porta di origine e destinazione per il traffico FTP?

All Logs

1-2 of 2

<

>

Time ▾	source_ip	source_port	destination_ip	destination_port	_id
▶ June 11th 2020, 03:53:09.086	192.168.0.11	52776	209.165.200.235	21	LDjqzXlB B6Cd-_0 SbfgO
▶ June 11th 2020, 03:53:09.086	192.168.0.11	52776	209.165.200.235	21	LTjqzXlB B6Cd-_0 SbfgO

1-2 of 2

<

>

R

Gli indirizzi IP e i numeri di porta identificati nei log di Kibana per il traffico FTP sono l'IP sorgente 192.168.0.11 sulla porta 52776 e l'IP di destinazione 209.165.200.235 sulla porta 21. Questa connessione rappresenta il canale di controllo FTP avviato dall'host client verso il servizio in ascolto sul server bersaglio.

L'ispezione dettagliata delle due voci di log in Kibana ha consentito di individuare nel campo `ftp_argument` la richiesta diretta alla risorsa `ftp://209.165.200.235/./confidential.txt`. Successivamente, selezionando il collegamento presente nel campo `alert_id` della medesima voce, si è acceduto alla trascrizione della transazione per analizzare nel dettaglio lo scambio di comandi in chiaro avvenuto durante la sessione FTP tra l'attaccante e il bersaglio.

D Quali sono le credenziali utente per accedere al sito FTP?

192.168.0.11:52776_209.165.200.235:21-6-477712488.pcap Log entry: <pre>{ "ts": "2020-06-11T03:53:09.086840Z", "uid": "C5GkeA4t8oXZdWTPr6", "id.orig_h": "192.168.0.11", "id.orig_p": "52776", "id.resp_h": "209.165.200.235", "id.resp_p": "21", "user": "analyst", "password": "<hidden>", "command": "STOR", "arg": "ftp://209.165.200.235/./confidential.txt", "mime_type": "text/plain", "reply_code": "226", "reply_msg": "Transfer complete.", "fuid": "FX1iV63eSMAEIN16S2" }</pre> Sensor Name: seconion-import Timestamp: 2020-06-11 03:53:09 Connection ID: CLI Src IP: 192.168.0.11 Dst IP: 209.165.200.235 Src Port: 52776 Dst Port: 21 OS Fingerprint: 192.168.0.11:52776 - UNKNOWN [S44:63:1:60:M1460,S,T,N,W7...?:?] (up: 3131 hrs) OS Fingerprint: -> 209.165.200.235:21 (link: ethernet/modem) DST: 220 (vsFTPD 2.3.4) DST: SRC: USER analyst SRC: DST: 331 Please specify the password. DST: SRC: PASS cyberops SRC: DST: 230 Login successful. DST:	
---	--

R

Le credenziali utilizzate per accedere al server FTP ed esfiltrare il file confidential.txt sono:

- Nome utente (Username): analyst
- Password: cyberops

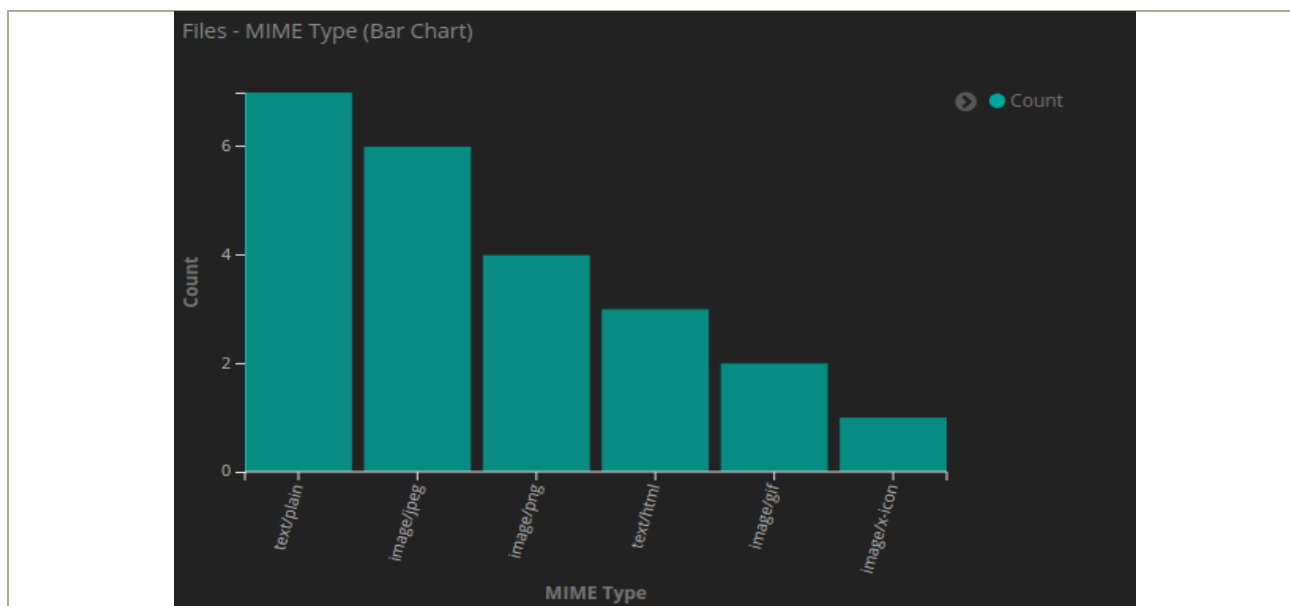
D Qual è il contenuto del file? Ricorda che uno dei servizi elencati nel grafico a torta è ftp_data.

R

Per accedere al contenuto del file esfiltrato, si è analizzato il canale dati del protocollo FTP (distinto dal canale di controllo). Tramite la sezione Discover di Kibana, si è filtrato il log relativo all'evento bro_ftpdata (servizio ftp-data), il quale registra il trasferimento effettivo dei payload. L'ispezione del dettaglio di questo log ha permesso di ricostruire il testo contenuto all'interno di confidential.txt prima della sua eliminazione dal sistema bersaglio.

Accedendo alla sezione Files sotto l'intestazione Zeek Hunting nella dashboard di Kibana, si è analizzata la distribuzione dei file intercettati durante la cattura mediante il grafico Files - MIME Type.

D Quali sono i diversi tipi di file?



R

I diversi tipi di file (espressi come tipi MIME) registrati e visualizzati nel grafico a barre sono:

- text/plain (7 file)
- image/jpeg (6 file)
- image/png (4 file)
- text/html (3 file)
- image/gif (2 file)
- image/x-icon (1 file)

D Guarda la sezione MIME Type dello schermo. Scorri fino all'intestazione Files - Source. Quali sono le sorgenti dei file elencati?

riservato diviso su tre righe inerente all'ultimo incidente di sicurezza ("CONFIDENTIAL DOCUMENT / DO NOT SHARE / This document contains information about the last security breach.").

D Qual è il contenuto testuale del file trasferito tramite FTP?

[192.168.0.11:49817_209.165.200.235:20-6-1473750472.pcap](#)

```
Log entry:
{"ts": "2020-06-11T03:53:09.088773Z", "fluid": "FX1jV63eSMAENi6S2", "tx_hosts": ["192.168.0.11"], "rx_hosts": ["209.165.200.235"], "conn_uids": ["C2Jv8MWV6Xg4lbb51"], "source": "FTP_DATA", "depth": 0, "analyzers": ["SHA1", "MD5"], "mime_type": "text/plain", "duration": 0.0, "is_orig": false, "seen_bytes": 102, "missing_bytes": 0, "overflow_bytes": 0, "timeout": false, "md5": "e7bc9c20bfd5666365379c91294d536b", "sha1": "f7f54acee0342f6161f8e63a10824ee11b330725"}
```

```
Sensor Name: seconion-import
Timestamp: 2020-06-11 03:53:09
Connection ID: CLI
Src IP: 192.168.0.11
Dst IP: 209.165.200.235
Src Port: 49817
Dst Port: 20
OS Fingerprint: 209.165.200.235:20 - Linux 2.6 (newer, 1) (up: 1 hrs)
OS Fingerprint: -> 192.168.0.11:49817 (distance 0, link: ethernet/modem)
SRC: CONFIDENTIAL DOCUMENT
SRC: DO NOT SHARE
SRC: This document contains information about the last security breach.
SRC:
```

```
DEBUG: Using archived data: /nsm/server_data/securityonion/archive/2020-06-11/seconion-import/192.168.0.11:49817_209.165.200.235:20-6.raw
QUERY: SELECT sid FROM sensor WHERE hostname='seconion-import' AND agent_type='pcap' LIMIT 1
CAPME: Processed transcript in 1.12 seconds: 0.48 0.44 0.00 0.21 0.00
```

[192.168.0.11:49817_209.165.200.235:20-6-1473750472.pcap](#)

R

Il contenuto testuale del file estratto dalla trascrizione della sessione dati FTP è il seguente:

CONFIDENTIAL DOCUMENT

DO NOT SHARE

This document contains information about the last security breach

Con tutte le informazioni raccolte finora, qual è la tua raccomandazione per fermare ulteriori accessi non autorizzati?

R

Per bloccare l'attacco in corso ed evitare ulteriori accessi non autorizzati sul sistema bersaglio (209.165.200.235), la strategia di remediation si articola su tre livelli operativi prioritari:

Contenimento immediato

- Revoca delle credenziali compromesse: Disabilitare l'account analyst o forzare un reset immediato della password (cyberops) su tutti i sistemi della rete aziendale.
- Isolamento dell'attaccante: Applicare sul firewall e sul sistema IPS una regola di drop/deny immediata per bloccare qualsiasi tipo di traffico proveniente dall'indirizzo IP malevolo 192.168.0.11.
- Arresto del servizio vulnerabile: Disattivare il demone FTP in chiaro (porta 21) sul server target per interrompere l'esposizione del canale di controllo.

Messa in sicurezza e remediation (Hardening)

- Migrazione a protocolli cifrati: Sostituire definitivamente il protocollo FTP non sicuro con SFTP (SSH File Transfer Protocol) o FTPS (FTP over TLS/SSL), garantendo la cifratura end-to-end sia per le credenziali di autenticazione sia per il trasferimento dati (FTP_DATA).

- Principio del Minimo Privilegio (PoLP): Restringere i permessi sul file system per l'utente analyst, revocando i diritti di eliminazione dei file (DELETE) e limitando l'accesso in lettura alle sole directory strettamente necessarie.
- Autenticazione avanzata: Sostituire l'uso di password statiche con l'autenticazione basata su chiavi SSH/certificati e introdurre l'autenticazione a più fattori (MFA).

Audit di persistenza e monitoraggio continuo

- Ricerca di meccanismi di persistenza: Effettuare un audit forense completo sul sistema 209.165.200.235 (ispezione dei log di sistema, verifica dei processi attivi, cronjob e utenti di sistema) per escludere la presenza di backdoor o webshell lasciate dall'attaccante.
- Implementazione di regole SIEM/NIDS: Configurare regole di alerting personalizzate su Security Onion (Snort/Zeek) per rilevare in tempo reale tentativi di login non cifrati o volumi anomali di dati trasferiti verso host esterni.